



82

[Research](#)[Vulnerability Dashboard](#)[Talks](#)[Tools](#)[About](#)

[Return to Team82 Research](#)

OPC-UA Deep Dive Series (Part 10): Security Tips for Asset Owners

Team82 / April 4th, 2024



Team82's [OPC UA Deep Dive Series](#) was always meant to be a compilation of our research into this most important of operational technology protocols. OPC UA standardizes data and communication between dozens of proprietary industrial control systems and devices that otherwise could not share information. Modern automation runs on OPC UA.

Therefore, it made sense to deeply examine the security of the protocol, starting with its [origins](#) and ultimately arriving at its [security features](#) and [attack surface](#). The installments of this comprehensive guide that we've published since last April dissects these concepts and also includes [practical and theoretical attacks against OPC UA](#), tools you can use to test the security of your implementations, and a [community of vendors and practitioners](#) who have collaborated with us to improve the safety and reliability of products built on top of the protocol.

In this final entry of the series, we will briefly recap the results of our research and also share helpful tips for asset owners. We are confident that OPC UA implementations are much more secure and robust. Most of our research was focused on helping OPC UA developers and vendors improve their protocol stack implementations, but we would like to share some tips for asset owners as well.

Outcomes of Team82's OPC UA Deep Dive Series

First, some outcomes:

- **Pwn2Own ICS:** We participated and demonstrated our OPC UA exploits at three Pwn2Own competitions: Pwn2Own ICS 2020, 2022, 2023
- **CVEs:** We found and reported on ~50 OPC-UA vulnerabilities/CVE across ~15 protocol stacks, which affect hundreds of OPC UA products.
- **Exploit Techniques:** We developed ~12 unique exploit techniques that are universal and affected multiple vendors and pushed to change the specs.
- **Open-Source Tools:** We have released open-source tools: our [OPC UA network fuzzer](#) and the [OPC UA exploit framework](#).
- **OPC UA Specifications:** We helped to improve the specifications and pushed the vendors toward better and more secure products.
- **OPC UA Slack:** We've collaborated with major OPC-UA vendors and created a safe place, via a dedicated Slack workspace) to discuss security issues, architecture, and possible improvements for OPC-UA protocol stack implementations.

- **Public Talks:** We've presented this research at major security conferences including [DEFCON](#) and [Black Hat](#)

OPC UA Security Best Practices for Asset Owners

Now, a do's and don'ts checklist of best practices you can use to assess the safety of your deployments.

Always: Update Software

Regularly updating software is crucial for maintaining security because updates often include patches for known vulnerabilities. Software updates should not only cover the OPC UA server but also any underlying operating systems, libraries, and dependencies. Implementing a robust update process ensures that security patches are applied promptly to mitigate potential threats.

Always: Enable Auditing and Logging

Enabling auditing allows for the tracking and monitoring of access and activities on the OPC UA server. Auditing helps in identifying security incidents, detecting anomalies, and providing accountability for actions performed within the system. By enabling auditing, organizations can enhance security posture and comply with regulatory requirements related to data protection and access control.

Always: Define Role-Based Access Controls

Role-based access control (RBAC) is essential for managing and controlling user access to OPC UA resources based on their roles and permissions.

Organizations should define roles and associated permissions tailored to their specific security requirements and operational needs.

RBAC helps in enforcing the principle of least privilege, ensuring that users only have access to the resources necessary for their tasks, thereby reducing the risk of unauthorized access and potential misuse of privileges.

Never: Expose OPC UA to the Internet

Exposing OPC UA servers directly to the internet increases the risk of unauthorized access and potential cyberattacks. It's recommended to deploy OPC UA servers within a secure network environment, preferably behind firewalls and other network security measures.

If remote access is required, consider using secure VPNs or implementing other secure access methods rather than exposing the servers directly to the internet.

Never: Allow Anonymous Authentication ❌

Allowing anonymous authentication poses significant security risks because it allows anyone to access the OPC UA server without providing credentials. Enforcing authentication ensures that only authorized users or devices can access the server, thereby preventing unauthorized access and potential data breaches.

Never: Allow Common Credentials ❌

Sharing or using common credentials across multiple users or systems increases the risk of credential theft and unauthorized access. Each user should have unique credentials, such as usernames and passwords, to access the OPC UA server. Implementing strong password policies and multi-factor authentication can further enhance security by adding layers of verification.

Never: Weak Security Mode (e.g. Invalid or None) ❌

OPC UA supports different security modes, including None, Sign, SignAndEncrypt.

Choosing None or an invalid security mode leaves communication unprotected, making it vulnerable to eavesdropping, tampering, and other security threats. It's essential to select an appropriate security mode based on the security requirements of the system and the sensitivity of the data being transmitted.

Never: Bad Security Policy (e.g. None) ❌

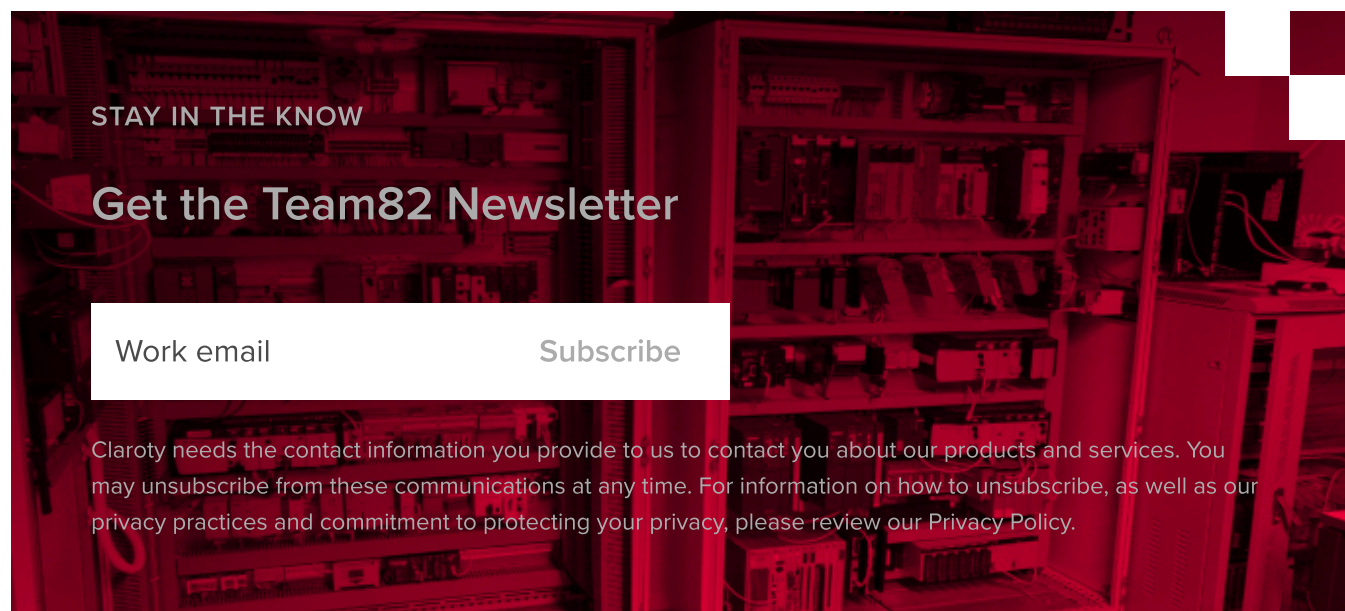
OPC UA defines various security policies, such as Basic256, Basic256Sha256, etc., which specify encryption and signature algorithms. Selecting the None security policy means no encryption or signature is applied to the communication, leaving it vulnerable to attacks.

Organizations should choose security policies that provide adequate protection based on their security requirements and compliance standards.

Avoid: Self-Signed Certificates

Using self-signed certificates for authentication and encryption. Doing so may introduce security risks, because they are not issued by a trusted Certificate Authority (CA). Self-signed certificates can be susceptible to spoofing attacks and may not provide the same level of trust and validation as certificates issued by trusted CAs. Whenever possible, organizations should run their own CAs because they need to control their trusted network of applications. OPC UA certificates are generally not designed to be verified primarily by a global CA, for example.

Share



STAY IN THE KNOW

Get the Team82 Newsletter

Claroty needs the contact information you provide to us to contact you about our products and services. You may unsubscribe from these communications at any time. For information on how to unsubscribe, as well as our privacy practices and commitment to protecting your privacy, please review our [Privacy Policy](#).

Recent Vulnerability Disclosures

CVE-2025-64130

CWE-79 IMPROPER NEUTRALIZATION OF INPUT DURING WEB PAGE GENERATION ('CROSS-SITE SCRIPTING')

The affected product is vulnerable to a reflected cross-site scripting vulnerability, which could allow a remote attacker to execute arbitrary JavaScript on the victim's browser.

Zenitel recommends users to upgrade to Version 9.3.3.0 or later.

CVSS V3: 9.8

CVE-2025-64129

CWE-787 OUT-OF-BOUNDS WRITE

The affected product is vulnerable to an out-of-bounds write vulnerability, which could allow a remote attacker to crash the device.

Zenitel recommends users to upgrade to Version 9.3.3.0 or later

CVSS V3: 7.6

CVE-2025-64128

CWE-78 IMPROPER NEUTRALIZATION OF SPECIAL ELEMENTS USED IN AN OS COMMAND ('OS COMMAND INJECTION')

An OS command injection vulnerability exists due to incomplete validation of user-supplied input. Validation fails to enforce sufficient formatting rules, which could permit attackers to append arbitrary data. This could allow an unauthenticated attacker to inject arbitrary commands.

Zenitel recommends users to upgrade to Version 9.3.3.0 or later

CVSS V3: 9.8

CVE-2025-64127

CWE-78 IMPROPER NEUTRALIZATION OF SPECIAL ELEMENTS USED IN AN OS COMMAND ('OS COMMAND INJECTION')

An OS command injection vulnerability exists due to insufficient sanitization of user-supplied input. The application accepts parameters that are later incorporated into OS commands without adequate validation. This could allow an unauthenticated attacker to execute arbitrary commands remotely.

Zenitel recommends users to upgrade to Version 9.3.3.0 or later.

CVSS V3: 9.8

CVE-2025-64126

CWE-78 IMPROPER NEUTRALIZATION OF SPECIAL ELEMENTS USED IN AN OS COMMAND ('OS COMMAND INJECTION')

An OS command injection vulnerability exists due to improper input validation. The application accepts a parameter directly from user input without verifying it is a valid IP address or filtering potentially malicious characters. This could allow an unauthenticated attacker to inject arbitrary commands.

Zenitel recommends users to upgrade to Version 9.3.3.0 or later

CVSS V3: 9.8

SOLUTIONS

[Claroty xDome Platform](#)

[Industrial Cybersecurity](#)

[Healthcare Cybersecurity](#)

[Commercial Cybersecurity](#)

[Public Sector Cybersecurity](#)

THREAT RESEARCH

[Team82 Home](#)

[Vulnerability Disclosure Dashboard](#)

[Research](#)

[PGP Key](#)

PARTNERS

[Partners](#)

[Technology Alliance Partners](#)

[Channel Partners](#)

[Become a Partner](#)

[Partner Login](#)

RESOURCES

[Resource Library](#)

[Blog](#)

[White Papers](#)

[Reports](#)

[Case Studies](#)

[Datasheets](#)

[Integration Briefs](#)

[Videos](#)

[Claroty Nexus](#)

COMPANY

[About Us](#)

[Careers](#)

[Leadership](#)

[Newsroom](#)

[xCel Enablement & Training](#)

[Trust Center](#)

[Customer Experience](#)

[Events](#)

[Environmental, Social, and Governance](#)

[Policies](#)

[Contact Us](#)



© 2026 Claroty. All rights reserved.

[Terms & Conditions](#) / [Privacy Policy](#)